restriction controls. The Commission preliminarily estimates that the ongoing annual labor cost to Participants of maintaining and reviewing the procedures and usage restriction controls and taking prompt action to remedy deficiencies in such policies, procedures and usage restriction controls would be approximately $289,700.[745]

The proposed amendments would require each Participant to engage an independent accounting firm annually to perform an examination of compliance with the policies required by Section 6.5(g)(i) and submit the examination report to the Commission.[746] The Commission preliminarily estimates that each Participant would incur labor costs of $5,600[747] to satisfy this requirement, as well as $57,500[748] in external consulting costs.

8. Regulator & Plan Processor Access

The Plan does not specify any restrictions on data sources used in the development of CAT systems, tools and applications. Currently, Plan Processor staff and contractors are not prohibited from using any CAT Data during development and testing activities.

---

745 See supra note 569. Labor cost estimate includes 28 hours by an Attorney, 28 hours by a Compliance Manager, 8 hours by a Senior Systems analyst, 8 hours by an Operations Specialist, 10 hours by a Chief Compliance Officer and 5 hours by a Director of Compliance. (28 hours x $426/hour + 28 hours x $317/hour + 8 hours x $291/hour + 8 hours x $140/hour + 10 hours x $543/hour + 5 hours x $500/hour) = $32,182. ($32,182 x 9) = $289,638.

746 See supra Part III.D.7. It is possible that Participants may realize economies of scale by engaging for this review at the Participant Group level. However, because the third party audit is required for each Participant regardless of Participant Group membership, the Commission preliminarily believes that it is appropriate to estimate this expense at the Participant level because efficiencies in third-party reviews is not under the Participants' direct control.

747 Labor cost estimate assumes 3 hours of Chief Compliance Officer labor, 5 hours of Compliance Manager labor, 3 hours of Compliance Attorney labor, 2 hours of Senior Systems Analyst labor, and 2 hours of Senior Programmer labor. (3 hours x $543/hour + 5 hours x $317/hour + 3 hours x $374/hour + 2 hours x $291/hour + 2 hours x $339/hour) = $5,596. ($5,596 per Participant x 25 Participants) = $139,900.

748 See supra note 574. ($57,500 per Participant x 25 Participants) = $1,437,500.

The proposed amendments would restrict such development and testing activities to non-production data in all cases for CAIS data. Further, they would restrict such development activities to non-production data for transactional data, unless it were not possible to do so. In such a case, development work could access the oldest available production data. The Commission preliminarily believes that these provisions may improve the confidentiality of CAT Data by preventing Plan Processor employees and contractors having exposure to CAT Data that might be used inappropriately.

The Commission preliminarily believes that test transactional data has already been prepared and used in the implementation of CAT reporting. However, the Plan Processor may need to prepare test data to be used in development work for systems, tools and applications that would access the CAIS. The Commission preliminarily estimates that the Plan Processor will incur costs of $10,270[749] to create this data and make it available to Plan Processor staff and contractors performing this development and testing work.

The Commission preliminarily believes that provisions of the proposed amendments that prohibit any use of CAT Data that has both regulatory and other uses may reduce Participants' use of CAT Data. While the Plan already prohibits commercial use of CAT Data, it does not specifically prohibit a regulatory use that also serves a non-regulatory purpose. This proposed amendment may prevent some Participants from using CAT Data in a rule filing that might lead the Commission to approve or disapprove a filing that could reduce trading costs to some investors. The Commission preliminarily believes that it is unlikely that such a rule filing would be approved or disapproved due to the Participants' inability to support their rule filings with

---

[749] Estimate assumes 20 hours of Senior Programmer labor and 10 hours of Senior Database Administrator labor. (20 hours x $339/hour + 10 hours x $349/hour) = $10,270.

CAT Data because Participants retain the ability to analyze their own in-house data in support of their rule filings, and to provide both quantitative arguments based on that in-house data as well as qualitative arguments that support those rule filings.

9. Secure Connectivity

The Plan allows CAT Data reporters and users to connect over private lines or secured public lines.[750] There is no specific requirement that any reporters use private lines and connectivity requirements do not differentiate between Participants and Industry Members in this regard.[751] Since approval of the Plan, the Participants have determined that they will connect to the CAT infrastructure using only private lines. However, the Commission recognizes that no language in the Plan requires that Participants will use only private lines in the future.

The Plan Processor requires two-factor authentication for connection to CAT. Authentication incorporates a geolocation blacklist including 16 countries. [752]

Currently, the CAT NMS Plan imposes requirements on data centers housing CAT Systems (whether public or private), but does not impose any geographical restrictions or guidelines. The Commission believes that all current CAT Data centers are located in the United States.

---

750 See supra Part II.I.

751 The distinction between Industry Members and Participants may be significant because while Participants are reporters of CAT Data, they are also users of CAT Data in their regulatory roles and thus have the ability to access and extract CAT Data. Industry Members are not potential users of CAT Data.

752 See FINRA CAT Industry Member Onboarding Guide at https://www.catnmsplan.com/sites/default/files/2020-02/FINRA-CAT-Onboarding-Guide-v1.5.pdf, item 7, page 19.

The proposed amendments would require Participants to connect to CAT infrastructure using private lines, and Industry Members to connect to CAT using secure methods such as private lines for machine-to-machine interfaces or encrypted Virtual Private Network connections over public lines for manual web-based submissions.[753] The proposed amendments would also require the Plan Processor to implement capabilities to restrict access through an "allow list" that would only allow access to CAT from countries where CAT reporting or regulatory use is both necessary and expected.[754] In addition, the proposed amendments would require that CAT Data centers be located in the United States.[755]

The Commission preliminarily believes these provisions of the proposed amendments will improve the security of CAT Data in two ways. First, although all Participants currently plan to connect to CAT using private lines, codifying this decision reduces the risk that, at a later date, one or more Participants might elect to connect with CAT in a less secure manner than with private lines, as they currently plan to connect to CAT. Furthermore, the Commission preliminarily believes that because Participants are not only reporters, but also users of CAT Data in their regulatory roles, ensuring that they connect to CAT in the most secure manner may further safeguard CAT Data by making the normal access mode for CAT Data be through private lines.[756] The Commission recognizes that this restriction may also prevent the Participants from

---

753 See supra Part II.I.

754 An "allow list" could be based on geography, server or IP. This is discussed further below.

755 See supra Part II.I.

756 The Commission preliminarily believes that use of the Online Targeted Query Tool through encrypted connections over public lines may still occur, but because of the 200,000 row limit to OTQT queries, it would be more difficult for a bad actor that gained access through a public line to access CAT Data if the Plan Processor is able to make other tools only available to users connecting through private lines. To the extent that the

electing to connect to CAT through a more secure method developed in the future that does not rely upon private lines. The Commission preliminarily believes this concern is mitigated by the Participants' ability to amend the Plan at a later date to allow such an access method.

Second, the Commission preliminarily believes that the requirement to establish "allow listing" procedures to allow connections to CAT only to those countries where CAT reporting or regulatory use is both necessary and expected might reduce the risk of a security breach by limiting connections from other sources.

The Commission preliminarily estimates that provisions of the proposed amendments concerning secure connectivity will cause the Plan Processor to incur initial one-time labor costs of $33,100[757] and ongoing annual labor costs of $3,100[758].

The Commission preliminarily estimates that requiring the Plan Processor to develop "allow listing" capability will cause the Plan Processor to incur initial one-time implementation labor costs of $13,700.[759] Maintaining this list will cause the Plan Processor to incur $1,200[760] in ongoing annual costs. In addition, the Plan Processor is estimated to incur $19,400[761] in one-time labor costs to implement procedures to allow access to CAT if the source location for a particular instance of access request cannot be determined technologically. The Commission

---

Plan Processor does not restrict access to other tools to users not connecting through public lines, this potential benefit would not be realized.

757 ($13,700 + $19,400) = $33,100.

758 ($1,200 + $1,900) = $3,100.

759 See supra note 577.

760 See supra note 579.

761 See supra note 581.

estimates that the Plan Processor will incur $1,900[762] in annual ongoing costs to maintain and enforce this restriction.

The Commission recognizes that the requirement that CAT data centers be located in the United States may prevent the Plan Processor from locating CAT data centers in other areas that might reduce the costs associated with maintaining CAT data centers. This could cause future costs of CAT to be higher than they might be otherwise.[763]

10. Breach Management Policies and Procedures

The Plan includes a requirement for reporting noncompliance incidents and security breaches to the Chief Compliance Officer.[764] The Plan also requires the Plan Processor to develop policies and procedures governing its responses to systems or data breaches, including a formal cyber incident response plan, and documentation of all information relevant to breaches.[765] CAT LLC has stated that in the event of unauthorized access to CAT Data that it will "…take all reasonable steps to investigate the incident, mitigate potential harm from the unauthorized access and protect the integrity of the CAT System. CAT LLC also will report unauthorized access to law enforcement, the SEC and other authorities as required or as it deems appropriate. CAT LLC will notify other parties of unauthorized access to CAT Data where required by law and as it otherwise deems appropriate. CAT LLC will maintain insurance that is required by law."[766]

---

762 See supra note 583.

763 See supra Part II.I for policy discussion of this requirement.

764 See supra Part II.J.

765 See supra Part II.J.

766 See CAT NMS Plan website frequently asked questions, "What happens if there is unauthorized access to CAT Data?" #S.11 at https://www.catnmsplan.com/faq.

The proposed amendments would require the formal cyber incident response plan to incorporate corrective actions and breach notifications, modeled after similar provisions in Regulation SCI.[767] Because of the lack of specificity in requirements for the cyber incident response in the Plan, it is possible that Participants might satisfy the existing provisions without providing for breach notifications to affected CAT Reporters, the Participants and the Commission, and prompt remediation of security threats. While the Commission believes it is unlikely the Participants would leave a security threat unaddressed, it also preliminarily believes that requiring procedures to be in place to deal with an incident ahead of time facilitates a quicker response should such an incident occur because procedures can specify who is to be involved in the response and in what capacity, and where authority lies in making the response.

The proposed amendments would require the formal cyber incident response plan to include taking appropriate corrective action that includes, at a minimum, mitigating potential harm to investors and market integrity, and devoting adequate resources to remedy the systems or data breach as soon as reasonably practicable. While the Commission preliminarily believes that the Participants are likely to take corrective action in the wake of a security breach without this explicit provision in the Plan, to the extent that this provision hastens the Participants' corrective action in the wake of a cyber incident, this provision may improve the security of CAT Data by reducing potential harm to investors and market integrity that may accrue if such a response were delayed.

In addition, the proposed amendments would require the Plan Processor to provide breach notifications of systems or data breaches to CAT Reporters that it reasonably estimates may have been affected, as well as to the Participants and the Commission, promptly after any

---

767 See supra Part II.J.

responsible Plan Processor personnel have a reasonable basis to conclude that a systems or data breach has occurred. In addition, the proposed amendments state that the cyber incident response plan must provide for breach notifications. The Commission preliminarily believes that breach notifications in the wake of a cyber incident may reduce harm to CAT reporters and investors whose data was exposed through a cyber incident. While the proposed amendments allow for delay in breach notification when such notification could expose environments from which CAT Data is accessed and analyzed to greater security risks, or compromise an investigation into the breach, the proposal would require the affirmative documentation of the reasons for the Plan Processor's determination to temporarily delay a breach notification, which is important to prevent the Plan Processor from improperly invoking this exception.

The proposed amendments would provide an exception to the requirement for breach notifications for systems or data breaches "that the Plan Processor reasonably estimates would have no or a de minimis impact on the Plan Processor's operations or on market participants." The Commission preliminarily believes that the exception to the breach notification requirement may help to focus the Plan Processor's resources on security issues with more significant impacts. Importantly, even for a breach that the Plan Processor believes to be a de minimis breach, the Plan Processor would be required to document all information relevant to such a breach. This would increase the likelihood that the Plan Processor has all the information necessary should its initial determination that a breach is de minimis prove to be incorrect, so that it could promptly provide breach notifications as required. In addition, maintaining documentation for all breaches, including de minimis breaches, would be helpful in identifying patterns among systems or data breaches. While the Commission preliminarily believes that these limitations on the breach notification requirement may slightly limit the benefits of breach

notification in the wake of a breach, it preliminarily believes these modifications may reduce the potential impact of a breach in the case of the delay notification provision because it would facilitate accurate later notification if deemed necessary.

The Commission preliminarily believes that requiring breach management policies and procedures and the cyber incident response plan to incorporate new elements required by the proposed amendments would result in a one-time labor cost of $49,800[768] for the Plan Processor.[769] Further, the Commission estimates that the Plan Processor will incur an ongoing labor cost of $42,200[770] to maintain, update and enforce these policies and procedures and the cyber incident response plan. The Commission believes that the Participants would incur initial labor costs of $9,500[771] for review and approval of the updated cyber incident response plan by the Operating Committee.[772]

11. Firm Designated ID and Allocation Reports

Prior to approval of the CAT NMS Plan, the Commission granted exemptive relief related to allocations of orders, which relieved the Participants from the requirement to link allocations to orders and allowed the usage of "Allocation Reports."[773] This exemptive relief is conditioned on, among other things, the Central Repository having the ability to use information

---

768 See supra note 585.

769 See supra Part III.D.9.

770 See supra note 588.

771 Labor costs include one hour per Participant of Vice President of Operations labor. Hourly rate estimated by using the median annual salary from www.payscale.com, multiply by 5.35 to account for other compensation, benefits and overhead and adjusting for 1800 hours of labor per year. (($128,159 x 5.35 / 1800 = $381/hour). (25 hours x $381/hour) = $9,525.

772 Id.

773 See supra Part II.K.

provided in Allocation Reports to link the subaccount holder to those with authority to trade on behalf of the account. However, the CAT NMS Plan as approved does not currently explicitly require Customer and Account Attributes be reported for Firm Designated IDs that are submitted in Allocation Reports, as it does for Firm Designed IDs that are submitted in connection with the original receipt or origination of an order.[774]

The proposed amendments would require that Customer and Account Attributes must be reported for Firm Designated IDs submitted in connection with Allocation Reports, and not just for Firm Designated IDs submitted in connection with the original receipt or origination of an order.[775] The Commission preliminarily believes that these provisions of the proposed amendments are unlikely to have significant economic benefits and costs because implementation of the exemptive relief is already underway and thus its benefits and costs are included in the baseline.

B. Impact on Efficiency, Competition, and Capital Formation

The Commission preliminarily believes that the proposed amendments are likely to have effects on efficiency and competition, with minimal if any effects on capital formation. The Commission anticipates moderate mixed effects on efficiency due to negative effects on the efficiency with which Participants perform their regulatory tasks but positive effects on the efficiency by which the CAT NMS Plan is implemented by Participants by standardizing policies and procedures across Participants and improving efficiencies in how Participants perform some regulatory activities. The Commission preliminarily believes that the proposed amendments will

---

774 See CAT NMS Plan, supra note 3, at Section 6.5(d)(ii)(C). However while the CAT NMS Plan does require such information for Firm Designated IDs that are submitted in Allocation Reports, it is required in a separate provision, Section 6.5(d)(iv). See supra Part II.K.

775 See supra Part II.K.